

Charte de Conformite RGPD

Projet Alumni CRM - Version complete et fidele au code source

1. Contexte Juridique

Le principal defi juridique d'un annuaire d'anciens reside dans le respect strict des donnees personnelles. Le CRM integre une tracabilite native et inalterable via la table CONSENTEMENT_RGPD, conforme au Reglement (UE) 2016/679 (RGPD) et a la loi Informatique et Libertes. Le chiffrement specifique des donnees de consentement n'est pas implemente au niveau applicatif (protection confiee aux mecanismes de l'infrastructure), et aucune fonctionnalite de notification de violation de donnees n'existe a ce jour.

2. Les 4 Types de Consentement Implements

Le systeme differencie quatre categories precises de consentement, chacune etant gerée independamment via des toggles dedies dans l'interface alumni (AlumniConsent.jsx).

Type (Backend)	Cle Frontend	Description (simplifiee)	Exemple
prise_de_contact	contact_allowed	Ecole / partenaires peuvent contacter.	Offres de postes, evenements
partage_donnees	data_sharing	Donnees statistiques anonymisees partagees.	Secteur, poste
enquetes	survey_participation	Participation aux enquetes alumni.	Evolution carriere, satisfaction
newsletter	newsletter	Reception de la newsletter.	Actualites, offres d'emploi

3. Mecanisme de Gestion du Consentement

3.1 Collecte du consentement

- Canal principal : formulaire d'inscription Web (AlumniRegistration.jsx).
- Canal secondaire prevu : questionnaire annuel (AlumniSurvey.jsx) ; a ce jour seul le canal 'web' est reellement emis par le frontend.
- Chaque consentement est enregistre avec : type_consentement, statut (actif/refuse), date_consentement, canal, id_etudiant.
- L'endpoint POST /consentements/ cree ou met a jour le consentement pour chaque type.
- L'interface de consentement informe l'alumni de la duree de conservation des donnees (suppression 6 mois apres anonymisation) et affiche le contact du DPO (contact@ionis-stm.com).

3.2 Modification et retrait

- L'alumni peut modifier ses preferences a tout moment via l'interface de consentement.
- Le retrait du consentement est modelise par un nouveau vote 'refuse' avec la date courante.
- L'interface affiche la date de derniere mise a jour du consentement.
- Une suppression physique d'un enregistrement reste possible via DELETE /consentements/{id_consentement}

(proprietaire ou admin) ; le retrait usuel conserve l'historique complet des votes.

3.3 Traçabilité

- Enregistrement de la date exacte du recueil (date_consentement).
- Identification formelle du canal de collecte (formulaire inscription, questionnaire).
- Historique complet des votes de consentement dans la base de donnees.

3.4 Consommation des consentements (relations fonctionnelles)

Chaque consentement est reellement consomme par une fonctionnalite du systeme : un refus (statut 'refuse') desactive l'usage correspondant. Un alumni sans vote sur un type reste eligible ('inconnu' tolere), par coherence avec l'emission du consentement. Le vote le plus recent est determine par une sous-requete corree identique partout (ORDER BY date_consentement DESC, id_consentement DESC LIMIT 1).

- 'newsletter' : recevoir les newsletters (POST /newsletter/envoyer, ciblage par promotion / secteur / consents actifs).
- 'enquetes' : acceder au questionnaire actif (GET /questionnaires/actif) et recevoir les relances (POST /admin/questionnaires/notifier). Un refus bloque la restitution du questionnaire (HTTP 403) et masque le lien 'Enquete annuelle' dans la navigation alumni (AlumniLayout.jsx).
- 'prise_de_contact' : recevoir newsletter et relances questionnaire ; un refus exclut l'alumni des deux envois (newsletter.py et questionnaires.py). C'est le seul consentement dont le refus declenche l'anonymisation du profil via cleanup.py (CONSETEMENT_ARCHIVE_TYPE = 'prise_de_contact').
- 'partage_donnees' : seul ce perimetre (alumni ayant accepte le partage) alimente les indicateurs partenaires GET /admin/indicateurs/partenaires (comptages et moyennes d'insertion anonymises, aucune donnee personnelle avec le partenaire).

4. Droits RGPD Implements dans l'Interface

L'interface alumni affiche et implemente les droits suivants :

- Droit d'acces a vos donnees personnelles : page de profil en lecture seule, suivi des demandes via GET /rgpd/demandes/moi et export json/Excel/CSV auto-service via GET /rgpd/export.
- Droit de rectification et de mise a jour (AlumniProfile.jsx).
- Droit a l'effacement (droit a l'oubli) : mentionne dans l'interface, implemente via un workflow de demandes auto-service (POST /rgpd/demandes) traite par anonymisation puis purge differee.
- Droit de retrait du consentement a tout moment (AlumniConsent.jsx avec toggles).

5. Modele de Donnees CONSETEMENT_RGPD

Champ	Type	Contraintes (simplifiees)	Exemple
id_etudiant	Entier (FK)	REFERENCES ETUDIANT, NOT NULL.	42
type_consentement	Enum / Chaîne	4 valeurs possibles.	newsletter
date_consentement	Date	NOT NULL, date du jour.	2025-09-14
statut	Chaîne	actif (accorde) / refuse (retire).	actif

Champ	Type	Contraintes (simplifiees)	Exemple
canal	Chaine	web questionnaire.	web
id_etudiant	Entier (FK)	REFERENCES ETUDIANT, NOT NULL.	42
type_consentement	Enum / Chaine	4 valeurs possibles.	newsletter
date_consentement	Date	NOT NULL, date du jour.	2025-09-14
statut	Chaine	actif (accorde) / refuse (retire).	actif
canal	Chaine	web questionnaire.	web

6. Workflow des Demandes RGPD (Effacement et Portabilite)

Au-dela du consentement, le CRM met en oeuvre un workflow complet de traitement des droits d'accès, d'effacement et de portabilite, base sur la table DEMANDE_RGPD :

- Depot auto-service : POST /rgpd/demandes (types 'export' ou 'suppression') ; suivi et annulation par l'alumni via GET /rgpd/demandes/moi et DELETE /rgpd/demandes/{id}.
- Cycle de statuts : envoyee -> en_traitement -> traitee/rejetee (contrainte SQL, migration 009), avec verrou anti-traitement parallele (prise_en_charge_par, date_prise_en_charge).
- Traitement d'une demande de suppression = anonymisation irreversible (email remplace par ANONYMISE_<id>@anonymise.io, donnees personnelles effacees), puis purge physique differee apres PURGE_DELAY_MONTHS mois (default 6) via purge.py (--dry-run disponible) ou POST /admin/demandes-rgpd/purge-anonymises.
- Portabilite : export json/Excel/CSV auto-service via GET /rgpd/export ; exports admin unitaires et en masse.
- Operations tracees dans AUDIT_LOG (acteur, action, details).